COMPTIA SECURITY+ SY0-701 DOMAIN 4 · SECURITY OPERATIONS (28%)

Security+ 4.7 · Scripting & Automation

Mestre CyberSec · **Lesson 4.7 — Scripting & Automation** (8:20) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Automation: patching, log collection, provisionamento, resposta a alerta. Python/Bash/PowerShell. Cuidado: o script também é surface — credenciais VAULT, code review, escopo, SCA de biblioteca.

💡 Key Exam Highlights & Critical Concepts

- Automation reduz erro humano — o principal source de breach
- Cuidado: script com credencial no código = risco

🎯 Exam Tips & Typical CompTIA Scenarios

- 'eliminates human error from repetitive tasks'=automation

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 4.7 — Scripting & Automation)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Automation (N/A)
Use of scripts or tools to perform repetitive IT tasks such as patching, log collection, provisioning, and alert response with minimal human intervention.

⚠️ ***Exam Trap:*** *CompTIA associa automação à redução ou eliminação do erro humano em tarefas repetitivas; não significa eliminar todos os riscos.*

• Scripting (N/A)
Writing small programs or scripts to automate administrative and security tasks; scripts become part of the attack surface if unmanaged.

⚠️ ***Exam Trap:*** *Script não é inerentemente inseguro, mas deve ter code review, escopo mínimo e credenciais protegidas.*

• Python (N/A)
General-purpose scripting language commonly used for automation, tooling, and security tasks in Security+.

⚠️ ***Exam Trap:*** *Reconheça Python como linguagem de automação; a prova pode citar scripts Python para tarefas repetitivas.*

• Bash (N/A)
Unix/Linux shell and scripting language used to automate command-line tasks and system administration.

⚠️ ***Exam Trap:*** *Bash é associado a automação em Linux/Unix; PowerShell é para Windows. Não confunda.*

• PowerShell (N/A)
Microsoft command-line shell and scripting language for automating Windows and cloud administrative tasks.

⚠️ ***Exam Trap:*** *PowerShell = automação Windows/Microsoft; Bash = Linux/Unix. A prova pode testar essa distinção.*

• Credential Vault (N/A)
Secure storage for credentials, API keys, and secrets used by scripts, preventing hard-coded passwords in code.

⚠️ ***Exam Trap:*** *Credencial hard-coded em script é risco grave; use vault ou secrets management para armazenar e auditar segredos.*

• **Code Review (N/A)**
Manual or automated inspection of scripts or code to identify security flaws, logic errors, and policy violations before deployment.

⚠️ ***Exam Trap:*** *Code review reduz risco de scripts inseguros; é um controle de desenvolvimento seguro, não apenas qualidade.*

• **Software Composition Analysis (SCA)**
Automated analysis of third-party libraries and dependencies to identify vulnerabilities and license issues in software or scripts.

⚠️ ***Exam Trap:*** *SCA foca em dependências ou bibliotecas vulneráveis; não confundir com SAST, que analisa código próprio, ou DAST, que testa a aplicação em execução.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A security team uses a Python script to automate patching for Linux servers. The script authenticates to each server using an SSH key stored in a plaintext configuration file on the automation host. An auditor flags this practice. Which change best addresses the finding while preserving automation?

A) Store the SSH key in a secrets vault and retrieve it at runtime using a short-lived token.

B) Encrypt the configuration file with a static password that is embedded in the script.

C) Restrict file permissions on the configuration file to the automation service account only.

D) Convert the script to PowerShell and run it from a Windows jump host.

QUESTION 2 · EXAM SCENARIO

A PowerShell script automatically disables user accounts when the SIEM detects a brute-force attack. The script runs under a domain administrator service account. A security review states that this violates least privilege. Which action should be taken?

A) Rewrite the script in Python to reduce the risk of PowerShell abuse.

B) Create a dedicated service account with permissions only to disable accounts in the targeted organizational units.

C) Require the script to prompt for domain administrator credentials each time it runs.

D) Move the script to a scheduled task on a domain controller.

QUESTION 3 · EXAM SCENARIO

A Bash log collection script sends application logs to a central SIEM. The script also copies all environment variables to a debug file stored on a shared server. Which security control should be applied first?

A) Enable file integrity monitoring on the shared server.

B) Implement input validation on the SIEM.

C) Sanitize or exclude sensitive values before writing debug data.

D) Compress and encrypt the debug file with a shared password.

QUESTION 4 · EXAM SCENARIO

A developer builds a Python automation tool for cloud provisioning. It depends on several open-source libraries listed in requirements.txt. Before deployment, security wants to identify known vulnerabilities in these libraries. Which action should be taken?

A) Perform static analysis only on the first-party Python code.

B) Enforce PowerShell execution policy on the build server.

C) Use a web application firewall in front of the automation API.

D) Run a software composition analysis (SCA) scan against the dependencies.

QUESTION 5 · EXAM SCENARIO

An automation script provisions new cloud VMs. To save time, it uses a cloud admin role with full subscription access. Which principle should be applied to reduce risk?

A) Separation of duties by having two administrators run the script.

B) Least privilege by scoping the role to only the required provisioning actions and resources.

C) Job rotation among cloud engineers.

D) Mandatory vacation for the automation account owner.

QUESTION 6 · EXAM SCENARIO

A production Bash script was edited directly on a server by an administrator to fix a log parsing issue. No pull request or testing was performed. What should be implemented to prevent this risk?

A) Store scripts in a version control system with mandatory peer review before deployment.

B) Disable Bash on all production servers.

C) Require scripts to run only during business hours.

D) Enable verbose logging for all shell commands.

QUESTION 7 · EXAM SCENARIO

A SIEM triggers an automated Python script that parses raw alert fields and blocks IP addresses. An attacker crafts a log entry containing shell metacharacters. Which weakness should be addressed?

A) Insufficient log retention.

B) Absence of full disk encryption.

C) Lack of input validation before passing alert data to system commands.

D) Weak Wi-Fi encryption.

QUESTION 8 · EXAM SCENARIO

A company automates patch deployment using a PowerShell script. The script downloads updates from an internal repository and installs them. Which control best ensures patches are legitimate and untampered?

A) Verify digital signatures or cryptographic hashes of packages before installation.

B) Schedule patching only during maintenance windows.

C) Log all patch installation events to a syslog server.

D) Run the script with a service account instead of a user account.

QUESTION 9 · EXAM SCENARIO

An automation account runs a scheduled Bash script to collect logs from many servers. The account's SSH key is long-lived and shared by three administrators. Security wants to improve credential management. What should be done?

A) Increase the SSH key length from 2048 to 4096 bits.

B) Store the key in a password-protected ZIP file.

C) Rename the automation account to hide its purpose.

D) Replace the shared key with short-lived certificates issued by an identity provider.

QUESTION 10 · EXAM SCENARIO

A security engineer writes a PowerShell script to respond to alerts by isolating endpoints. The script can modify any endpoint in the corporate domain. Which action best aligns with secure automation practices?

A) Obfuscate the script to prevent attackers from reading it.

B) Limit the script's permissions to a defined endpoint group and require approval for high-impact actions.

C) Run the script only from the security engineer's workstation.

D) Configure the script to bypass execution policy for reliability.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Store the SSH key in a secrets vault and retrieve it at runtime using a short-lived token.

A secrets vault allows credentials to be stored centrally, access-controlled, audited, and rotated without hardcoding them in scripts or plaintext files. Embedded static passwords and file permissions do not remove the exposure of a long-lived secret, and changing the scripting language or host platform does not address the credential storage weakness.

Question 2: Option B — Create a dedicated service account with permissions only to disable accounts in the targeted organizational units.

The script only needs to disable specific accounts, so a dedicated service account scoped to the required organizational units follows least privilege. Rewriting the script, prompting for elevated credentials, or running it on a domain controller does not reduce the excessive privileges granted to the automation process.

Question 3: Option C — Sanitize or exclude sensitive values before writing debug data.

Environment variables often contain API keys, tokens, and passwords. Sanitizing or excluding sensitive values before writing debug data prevents secret leakage at the source. File integrity monitoring is detective, SIEM validation does not protect the debug file, and encrypting with a shared password still leaves sensitive data exposed to anyone with the password.

Question 4: Option D — Run a software composition analysis (SCA) scan against the dependencies.

Software composition analysis examines third-party and open-source dependencies for known vulnerabilities, outdated components, and license issues. Static analysis of first-party code may miss library flaws, PowerShell execution policy is unrelated to Python dependencies, and a web application firewall does not identify vulnerable libraries in the build.

Question 5: Option B — Least privilege by scoping the role to only the required provisioning actions and resources.

Least privilege reduces the blast radius if the automation script or its credentials are compromised. Scoping the role to only required provisioning actions and resources directly limits what the script can do. Separation of duties, job rotation, and mandatory vacation are administrative controls that do not replace technical permission scoping.

Question 6: Option A — Store scripts in a version control system with mandatory peer review before deployment.

Version control with mandatory peer review provides change tracking, accountability, and review before production changes. Disabling Bash is generally impractical and may break operations, time restrictions do not prevent unauthorized edits, and verbose logging is detective rather than preventive.

Question 7: Option C — Lack of input validation before passing alert data to system commands.

If alert data is passed to system commands without validation, shell metacharacters can lead to command injection. Input validation, safe API calls, and parameterized commands help prevent the automation script from executing attacker-controlled commands. Log retention, disk encryption, and Wi-Fi encryption do not address this injection weakness.

Question 8: Option A — Verify digital signatures or cryptographic hashes of packages before installation.

Verifying digital signatures or cryptographic hashes ensures package integrity and authenticity before installation. Maintenance windows reduce disruption, logging provides visibility, and using a service account changes execution context, but none of those controls prove that the patch has not been tampered with.

Question 9: Option D — Replace the shared key with short-lived certificates issued by an identity provider.

Short-lived certificates reduce the impact of credential theft, eliminate shared long-lived keys, and allow centralized issuance and expiration. Increasing key length does not solve sharing, password-protected ZIP files are weak for automation secrets, and renaming the account provides no security benefit.

Question 10: Option B — Limit the script's permissions to a defined endpoint group and require approval for high-impact actions.

Scoping permissions to a defined endpoint group follows least privilege, and approval for high-impact actions adds a control against accidental or malicious mass isolation. Obfuscation is not a security control, running from one workstation does not limit permissions, and bypassing execution policy weakens script security.